

CWE AI Working Group: Modification Subgroup

August 15, 2025

Attendance

Steve Christey Coley	Michael Simon	Monika Akbar
Erick Galinkin	Ray Pompon	Tonisha Pinckney
Farah Rahman	Farah Rahman	

Agenda

- Status Updates
- Hyperparameter Submission Development
- Work Planning

Meeting Notes:

Status Updates: Steve provided an update on the next CWE release (4.18), which is scheduled for release on September 9th. The content development repository (CDR) is fully public. An outstanding item to complete is the addition of new subgroup leaders.

Hyperparameter Submission Development

Steve and Erick discussed the use of the term "excessive" in AI model configuration, focusing on the implications of setting inference parameters that result in excessive iterations. They considered whether to capture security policy violations in the extended description rather than the main description to avoid clutter.

- The term "excessive" is subjective and depends on the user's perspective, especially in the context of CWE-834 (excessive iteration).
- Erick suggested that certain inference parameters might result in excessive iterations, leading to performance issues.

Farah proposed introducing a confidence level for AI models in security policies as a potential standard.

This document includes content generated with the assistance of Microsoft Teams Copilot, a generative AI tool. Microsoft Teams Copilot was used to generate the initial draft of the meeting minutes and provide suggestions for summarizing key discussion points. All AI-generated content has been reviewed and edited by the CVE Program prior to publishing. Please report any inaccuracies or other issues to the CVE Program.

- Erick highlighted the challenges of being prescriptive in the AI space due to the vast number of models and the adversarial nature of security benchmarking.
- Model variability complicates the establishment of a consistent confidence level, requiring flexibility in security policies.

Steve and Erick discussed the inherent fuzziness in security policies, noting debates about the severity of vulnerabilities and whether they constitute security issues or just bugs.

- They emphasized the importance of avoiding prescriptive measures in CWE to account for variability and limits associated with dependence on context. The need for clear and explicit security policies to reduce ambiguity was highlighted.

Steve and Erick reviewed the development of a demonstrative example, including a sample configuration file and code snippets to illustrate potential security issues in AI models.

- Erick agreed to work with Steve offline to provide sample config files and code extracts from previous runs. Code snippets will show how certain configurations can lead to security vulnerabilities.

Steve and Erick discussed phases of the software development lifecycle where AI weaknesses might be introduced, focusing on model training and system configuration.

- Model training was debated as a phase where weaknesses could be introduced, considering whether it fits under implementation or build/compilation in the CWE framework.
- System configuration, particularly insecure hyperparameter settings during deployment, was identified as another phase.
- They debated how to categorize these phases within the existing CWE framework and considered the need for more flexibility in future versions.

Work Planning

Steve outlined potential future work, including discussions on bias in AI models and input validation in generative AI applications. Steve mentioned Kurt Seifried's submission about bias in AI models, pending for a year and a half, and suggested focused discussions to decide next steps.

- Steve's own submission on input validation in generative AI applications was noted as having major problems and suggested to be tabled for now.
- Introduced a new submission about not neutralizing configurations used for an MCP client and sought feedback on its relevance to existing CWEs.

Erick and Chris identified the new MCP client configuration submission as potentially overlapping with existing CWEs related to command injection (CWE-77) and privilege assignment.

Chris questioned whether the MCP client should have the privilege to execute OS commands, suggesting this might be a security risk.

- The issue might be better addressed as a specific instance of existing weaknesses (CWEs 77, 1426, 1427) rather than creating a new CWE entry.

Action Items:

- **Sample Configuration File:** Work with Erick to create a sample configuration file and code extract showing interaction with the model. (Steve)
- **Model Training and Deployment Phases:** Spell out the different phases of training, including pre-training, instruction tuning, task-specific fine-tuning, and safety post-training, in the notes. (Erick Galinkin)
- **New Entry for CWE 4.18:** Start a discussion in CDR shortly after the meeting to continue the discussion on the new entry for CWE 4.18. (Steve)
- **Future Work on Bias in AI Models:** Have a focused discussion on Kurt Seifried's submission about bias in AI models and decide on the next steps. (Group)
- **Review of New Submission:** Conduct an initial detailed review of the new submission about not neutralizing configurations used for an MCP client and provide feedback to the original submitter. (Steve)